

Log Analysis for Incident Response



Content

- Investigations 101
 - Network Investigations
 - Host Investigations
 - Application Investigations
- Log Analysis
 - Event logs
 - Syslog
 - Firewall logs
 - Web application firewall logs
 - Proxy
 - IDS/IPS logs



Labs:

- Event Viewer Log analysis
- Proxy Log Analysis
- Firewall Log Analysis

Investigation 101 (Foundation)

- **Define scope**

- What triggered investigation? (alert, anomaly, IOC)
- Affected asset: IP / host / user / app

- **Collect evidence**

- Logs (SIEM / EDR / firewall / OS)
- Memory / disk artifacts
- Network captures

- **Analyze**

- Timeline creation
- IOC matching
- Behavior analysis

- **Contain & respond**

- Block IP/domain
- Isolate endpoint
- Patch vulnerability

- **Document**

- Root cause
- MITRE ATT&CK mapping
- Lessons learned

Network Investigations

- Network investigations focus on analyzing network activity to **detect, scope, and understand security incidents** such as intrusions, malware communications, lateral movement, and data exfiltration.
- They are a critical component of **incident response, threat hunting, and digital forensics**.
- Objectives of Network Investigations:
 - Identify initial compromise vectors
 - Detect command-and-control (C2) communications
 - Trace lateral movement paths
 - Determine data exfiltration attempts
 - Reconstruct attacker timelines
 - Support containment and remediation decisions



Data Sources for Network Investigations

▪ Network Traffic Data

- Full packet capture (PCAP)
- NetFlow / sFlow / IPFIX
- Network taps and SPAN ports

▪ Network Security Logs

- Firewall logs
- IDS/IPS alerts (Snort, Suricata)
- Proxy and secure web gateway logs
- VPN and remote access logs

▪ DNS & Internet Logs

- DNS query and response logs
- DHCP logs
- Email gateway logs

Network Investigation Process

Step 1: Incident Scoping

- Identify suspicious IPs, domains, and ports
- Determine affected subnets and hosts
- Define time window for analysis

Step 2: Traffic Analysis

- Analyze inbound vs outbound traffic
- Identify anomalous protocols or ports
- Detect beaconing patterns

Step 3: Lateral Movement Detection

- SMB, RDP, WinRM, SSH traffic analysis
- Abnormal authentication flows
- East-west traffic spikes

Step 4: Data Exfiltration Analysis

- Large outbound transfers
- Unusual destinations
- DNS tunneling or HTTPS abuse

Step 5: Attribution & Context

- Enrich with threat intelligence
- Map activity to MITRE ATT&CK

Common Network Attack Patterns

- **Reconnaissance**

- Port scanning
- Network mapping

- **Command and Control (C2)**

- Periodic outbound connections
- Rare domains or IPs

- **Lateral Movement**

- Administrative protocol abuse
- Pass-the-Hash over SMB

- **Exfiltration**

- Long-lived HTTPS sessions
- Abnormal DNS query sizes

Tools Used in Network Investigations

- **Wireshark** – Packet-level analysis
- **Zeek** – Network security monitoring
- **Suricata** – IDS/IPS and traffic analysis
- **NetFlow Analyzers** – Traffic patterns
- **SIEM** – Correlation and alerting
- **EDR/XDR** – Endpoint-network correlation



Host Investigations

- Host investigations focus on analyzing **individual systems (endpoints or servers)** to determine **how they were compromised, what actions were performed, and whether persistence or data theft occurred.**
- They are a critical pillar of incident response, complementing network and identity investigations.
- Objectives of Host Investigations:
 - Identify initial compromise on the host
 - Detect malware execution and persistence
 - Confirm privilege escalation attempts
 - Determine lateral movement initiation
 - Assess data access or manipulation
 - Collect forensic evidence for legal and compliance needs



Host Data Sources

- **Operating System Logs**

- Windows Event Logs (Security, System, Application)
- Linux logs (auth.log, syslog, auditd)

- **Endpoint Telemetry**

- EDR/XDR process trees
- File creation/modification events
- Registry or configuration changes
- Memory artifacts

- **Host Artifacts**

- Prefetch files (Windows)
- Scheduled tasks / cron jobs
- Services and startup items
- Browser history and downloads
- Command history (PowerShell, Bash)

Host Investigation Process

Step 1: Host Identification & Isolation

- Identify affected host(s)
- Isolate from network (EDR containment)
- Preserve volatile data where possible

Step 2: Triage & Evidence Collection

- Capture memory image (if feasible)
- Collect disk artifacts
- Export relevant logs
- Document system state

3: Timeline Reconstruction

- Correlate process execution
- File and registry modifications
- User logon activity
- System changes

Step 4: Malware & Persistence Analysis

- Identify malicious binaries or scripts
- Analyze persistence mechanisms
- Review startup entries and services

Step 5: Impact Assessment

- Determine accessed or modified data
- Identify credential compromise
- Assess trustworthiness of the host

Common Host-Based Attack Indicators

▪ **Malware Execution**

- Unknown processes running from user directories
- Suspicious PowerShell or script execution

▪ **Privilege Escalation**

- New admin accounts
- Token manipulation events
- Unexpected privilege assignments

▪ **Persistence**

- Scheduled tasks with obfuscated commands
- Registry Run keys
- Modified system services

▪ **Defense Evasion**

- Disabled antivirus or logging
- Cleared event logs

Tools Used in Host Investigations

- **EDR/XDR:** Microsoft Defender, CrowdStrike
- **Forensics:** FTK, EnCase, Autopsy
- **Memory Analysis:** Volatility
- **Live Response:** KAPE, Velociraptor
- **Log Analysis:** Windows Event Viewer, Sysmon



Application Investigations

- Application investigations focus on analyzing **application-layer activity** to determine whether a security incident involved **exploitation of application logic, vulnerabilities, misconfigurations, or abused credentials**.
- These investigations are critical for identifying **data breaches, web attacks, and business logic abuse**.
- Objectives of Application Investigations are:
 - ✓ Identify application-layer attack vectors
 - ✓ Detect unauthorized access or data exposure
 - ✓ Determine exploited vulnerabilities or logic flaws
 - ✓ Reconstruct attacker actions within the application
 - ✓ Assess impact on data confidentiality and integrity
 - ✓ Support remediation and secure code improvements



Application Data Sources

- **Application Logs**

- Authentication and authorization logs
- API access logs
- Transaction and audit logs
- Error and exception logs

- **Web Server Logs**

- IIS, Apache, Nginx access and error logs
- Reverse proxy / load balancer logs

- **Database Logs**

- Query logs
- Audit trails
- Access and privilege changes

- **Security Controls**

- Web Application Firewall (WAF) logs
- API gateway logs
- IAM / OAuth logs

Application Investigation Process

Step 1: Scope the Application Incident

- Identify affected applications, APIs, and environments
- Define the time window
- Identify impacted users and roles

Step 2: Analyze Authentication & Access

- Review login attempts and token usage
- Identify bypassed authentication or abused sessions
- Detect privilege escalation within the app

Step 3: Analyze Requests & Payloads

- Inspect HTTP methods, parameters, and payloads
- Identify SQL injection, command injection, or XSS patterns
- Detect API abuse and enumeration

Step 4: Database & Data Impact Analysis

- Identify unauthorized data access or modification
- Review export, download, or bulk access events
- Validate data integrity

Step 5: Root Cause Identification

- Vulnerability exploitation vs credential abuse
- Misconfiguration vs code flaw
- Third-party or supply-chain involvement

Common Application Attack Indicators

Authentication Abuse

- Repeated login failures followed by success
- Access from unusual geolocations
- Token reuse across IPs

Injection Attacks

- SQL keywords in request parameters
- Error-based or time-based injection patterns

Abuse

- Excessive API calls
- Missing authorization checks
- Enumeration of object IDs

Business Logic Abuse

- Bypassing approval workflows
- Price or quantity manipulation
- Unauthorized state transitions

Tools Used in Application Investigations

- **SIEM:** Splunk, Sentinel
- **WAF:** Cloudflare, F5, AWS WAF
- **APM:** New Relic, Dynatrace
- **DAST:** Burp Suite, OWASP ZAP
- **Database Auditing:** Native DB audit tools

Log Analysis



Log Analysis

- Event logs
- Syslog
- Firewall logs
- Web application firewall logs
- Proxy
- IDS/IPS logs

Event logs

- Purpose:
 - Detect security incidents and anomalies
 - Support investigations and root-cause analysis
 - Provide forensic evidence
 - Enable compliance and audit reporting
 - Monitor system health and performance

Operating System Event Logs

▪ Windows Event Logs

- Security Log – Authentication, authorization, policy changes
 - System Log – OS-level events, services, drivers
 - Application Log – Application-specific events
-
- Critical Security Event IDs (Examples)
 - **4624** – Successful logon
 - **4625** – Failed logon
 - **4672** – Special privileges assigned
 - **4688** – Process creation
 - **4720** – User account created
 - **4728** – User added to privileged group

▪ Linux Logs

- /var/log/auth.log – Authentication events
- /var/log/syslog – System activity
- /var/log/audit/audit.log – Security auditing
- /var/log/secure – Security-related events

Event Log Lifecycle

- **Generation** – Event occurs
- **Collection** – Centralized logging
- **Normalization** – Common format
- **Correlation** – Pattern detection
- **Storage** – Secure retention
- **Analysis** – Investigation and response

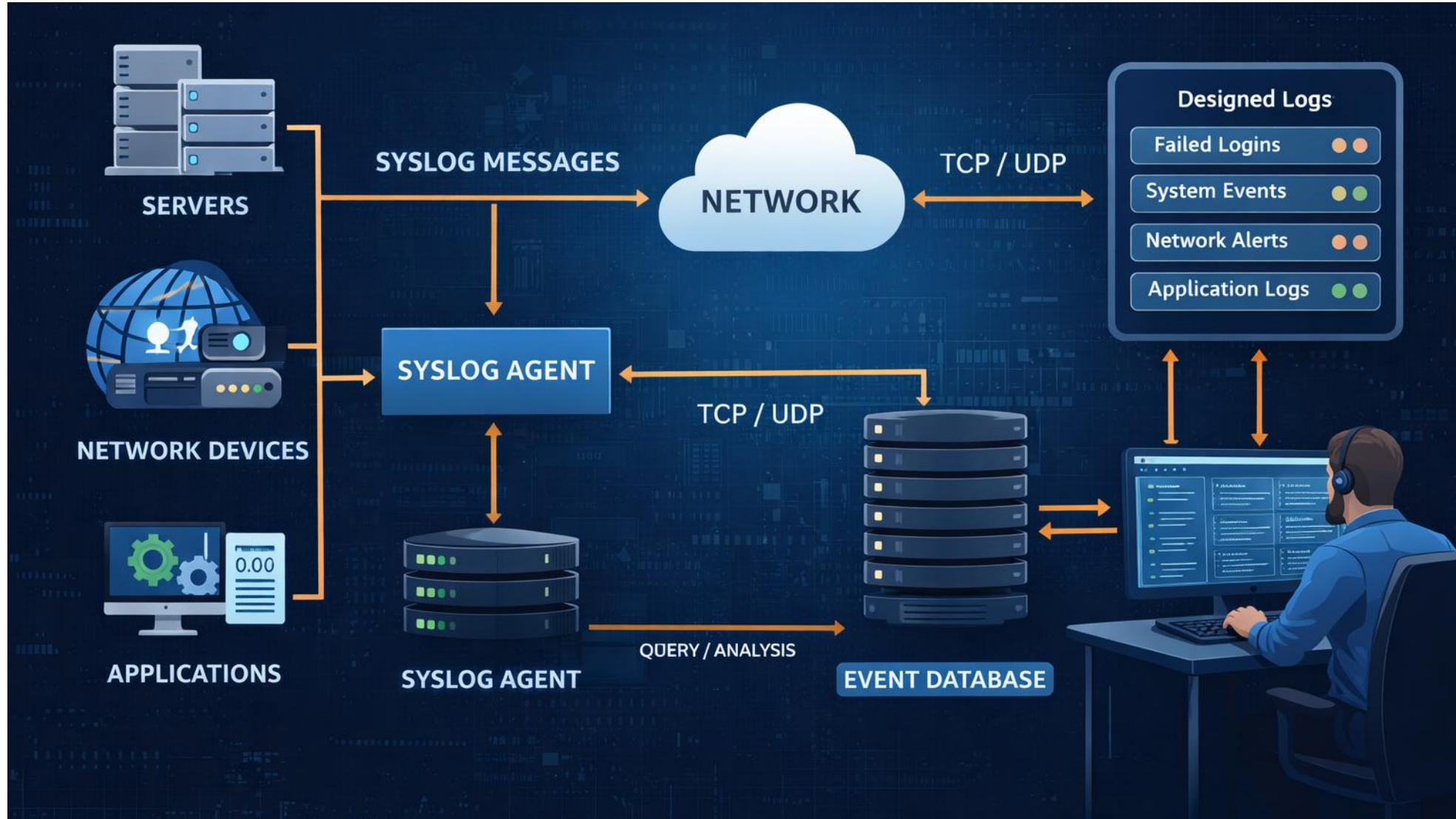


Syslog

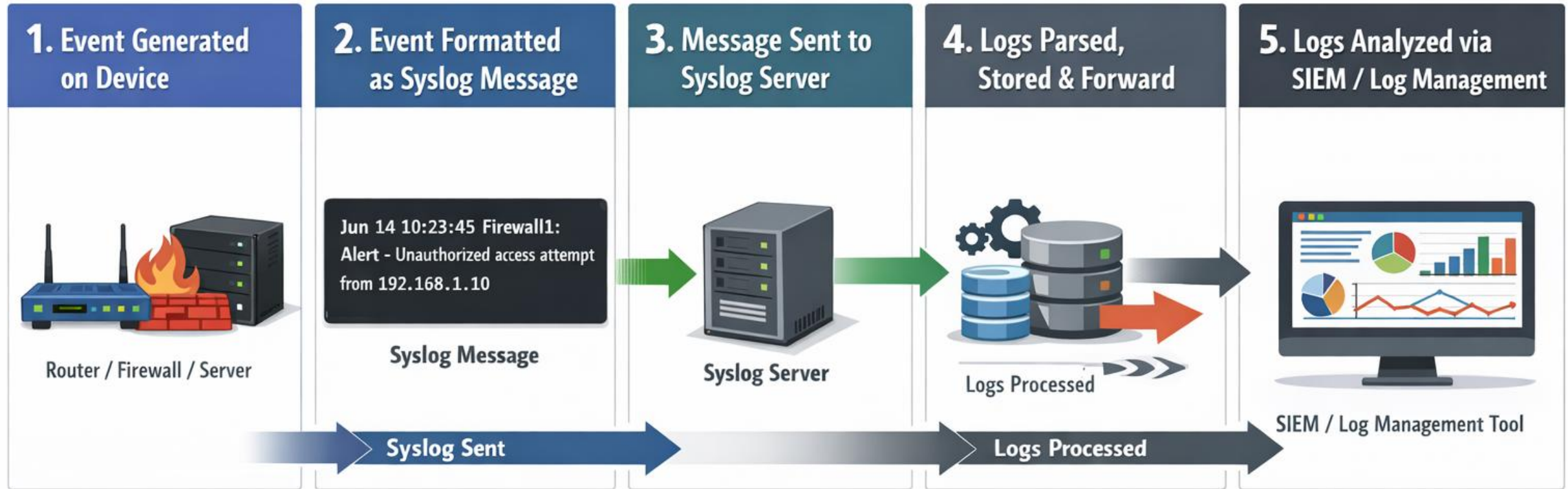
- Syslog is a standard logging protocol used to **collect, transmit, and store event messages** from network devices, servers, and applications in a **centralized location**.
- It is widely used in security monitoring, incident response, and compliance.
- Purpose of Syslog:
 - ✓ Centralize logs from diverse systems
 - ✓ Enable real-time monitoring and alerting
 - ✓ Support incident detection and investigation
 - ✓ Provide long-term log retention
 - ✓ Meet audit and compliance requirements



Architectural working of Syslog



How Syslog Works?



Syslog Message Structure

- A standard syslog message includes:
 - Priority (PRI) – Severity + Facility
 - Timestamp
 - Hostname / IP
 - Application name / Tag
 - Message content



Common Tools

- rsyslog
- syslog-ng
- Graylog
- Splunk
- ELK Stack

Firewall logs

- Firewall logs record allowed and denied network traffic as it traverses a firewall.
- They provide critical visibility into
 - network-based attacks,
 - policy violations,
 - lateral movement, and
 - data exfiltration,
- making them a primary data source for incident detection and investigation.

Purpose of Firewall Logs

Monitor inbound
and outbound
traffic

Detect
unauthorized
access attempts

Identify attack
patterns and
scanning activity

Support incident
investigations

Validate firewall
policy
effectiveness

Meet audit and
compliance
requirements



Types of Firewall Logs

▪ Traffic (Access) Logs

- Record traffic decisions based on firewall rules.
- Port scanning detection
- Unauthorized access attempts
- Lateral movement analysis

▪ Threat / Security Logs

- Generated by next-generation firewalls (NGFWs).
- Exploit detection
- Malware communications
- Active attack identification

▪ System & Configuration Logs

- Track firewall operational events.
- Privileged access monitoring
- Insider threat detection
- Change auditing

TimeCreated	Id	Level	DisplayName	Message
03-Jan-26 9:53:35 AM	2097	Information		A rule has been added to the Windows Defender Firewall exception list....
03-Jan-26 9:53:35 AM	2097	Information		A rule has been added to the Windows Defender Firewall exception list....
03-Jan-26 9:53:35 AM	2052	Information		A rule has been deleted in the Windows Defender Firewall exception list....
03-Jan-26 9:53:35 AM	2052	Information		A rule has been deleted in the Windows Defender Firewall exception list....
03-Jan-26 9:41:38 AM	2010	Information		Network profile changed on an interface....
03-Jan-26 9:41:36 AM	2051	Information		Tenant Restrictions Policy Update...
03-Jan-26 9:41:36 AM	2059	Information		All rules have been deleted from the Windows Defender Firewall configuration
03-Jan-26 9:41:36 AM	2084	Information		Added a Duplicate Rule...



Firewall Logs in Incident Response

- **Detection**

- Multiple denied connections → scanning
- Outbound connections to rare IPs → malware C2

- **Analysis**

- Timeline reconstruction
- Identify compromised hosts

- **Containment**

- Block malicious IPs/domains
- Restrict outbound traffic

- **Recovery**

- Validate no further malicious traffic

Common Attack Indicators in Firewall Logs

- **Reconnaissance**

- Sequential port access attempts
- Repeated denied traffic from same IP

- **Malware & C2**

- Regular outbound connections at fixed intervals
- Connections to newly registered domains

- **Data Exfiltration**

- Large outbound data transfers
- Long-lived sessions to unknown destinations

- **Lateral Movement**

- East-west traffic on admin ports (SMB, RDP)

Web application firewall logs

- Web Application Firewall (WAF) logs capture detailed information about **HTTP/HTTPS** requests and responses that are **inspected, allowed, blocked, or challenged** by a WAF.
- They are essential for detecting and investigating web attacks, API abuse, and application-layer intrusions.
- Purpose of WAF Logs
 - ✓ Detect web-based attacks (OWASP Top 10)
 - ✓ Identify malicious payloads and exploit attempts
 - ✓ Monitor API usage and abuse
 - ✓ Support incident investigations and forensics
 - ✓ Validate effectiveness of WAF rules
 - ✓ Meet compliance and audit requirements



Types of WAF Logs

Access / Request Logs

- Record all HTTP/S requests processed by the WAF.
- Typical Fields
 - Client IP
 - HTTP method (GET, POST, PUT, DELETE)
 - URI / URL
 - HTTP status code
 - User-Agent
 - Bytes sent/received
 - Timestamp

Bot & Rate-Limiting Logs

- Track automated or abusive traffic.
- Examples
 - Bot detection events
 - Excessive request rates
 - Credential stuffing attempts

Security / Attack Logs

- Generated when requests trigger WAF security rules.
- Typical Fields
 - Attack type (SQLi, XSS, RCE, LFI)
 - Matched rule ID and name
 - Action taken (block, allow, log, challenge)
 - Payload snippet
 - Severity

Common Attack Indicators in WAF Logs

- **SQL Injection (SQLi)**

- ' OR 1=1 --
- UNION SELECT statements
- Time-based delays

- **Cross-Site Scripting (XSS)**

- <script> tags
- JavaScript injection

- **Remote Code Execution (RCE)**

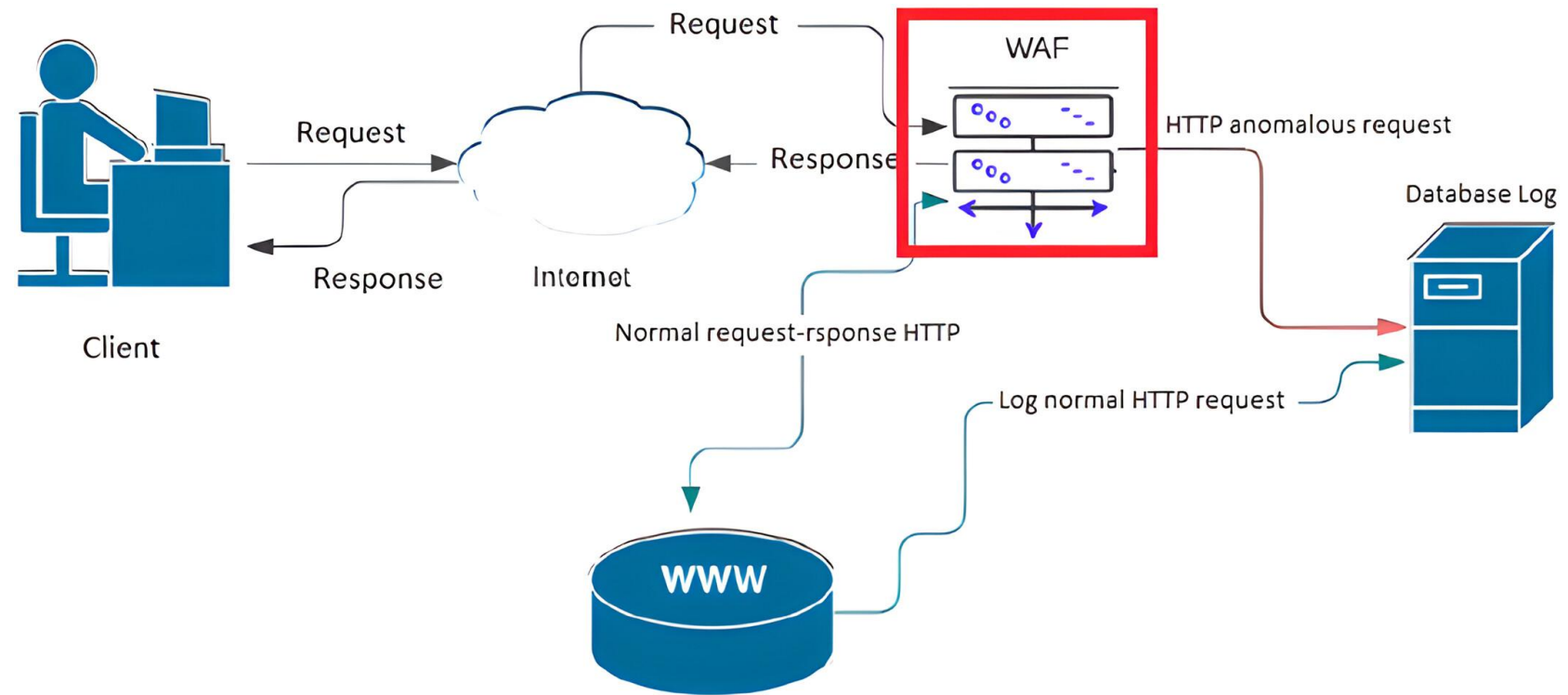
- ;, &&, | in parameters
- Command execution strings

- **API Abuse**

- Excessive API calls
- Missing authorization headers
- ID enumeration

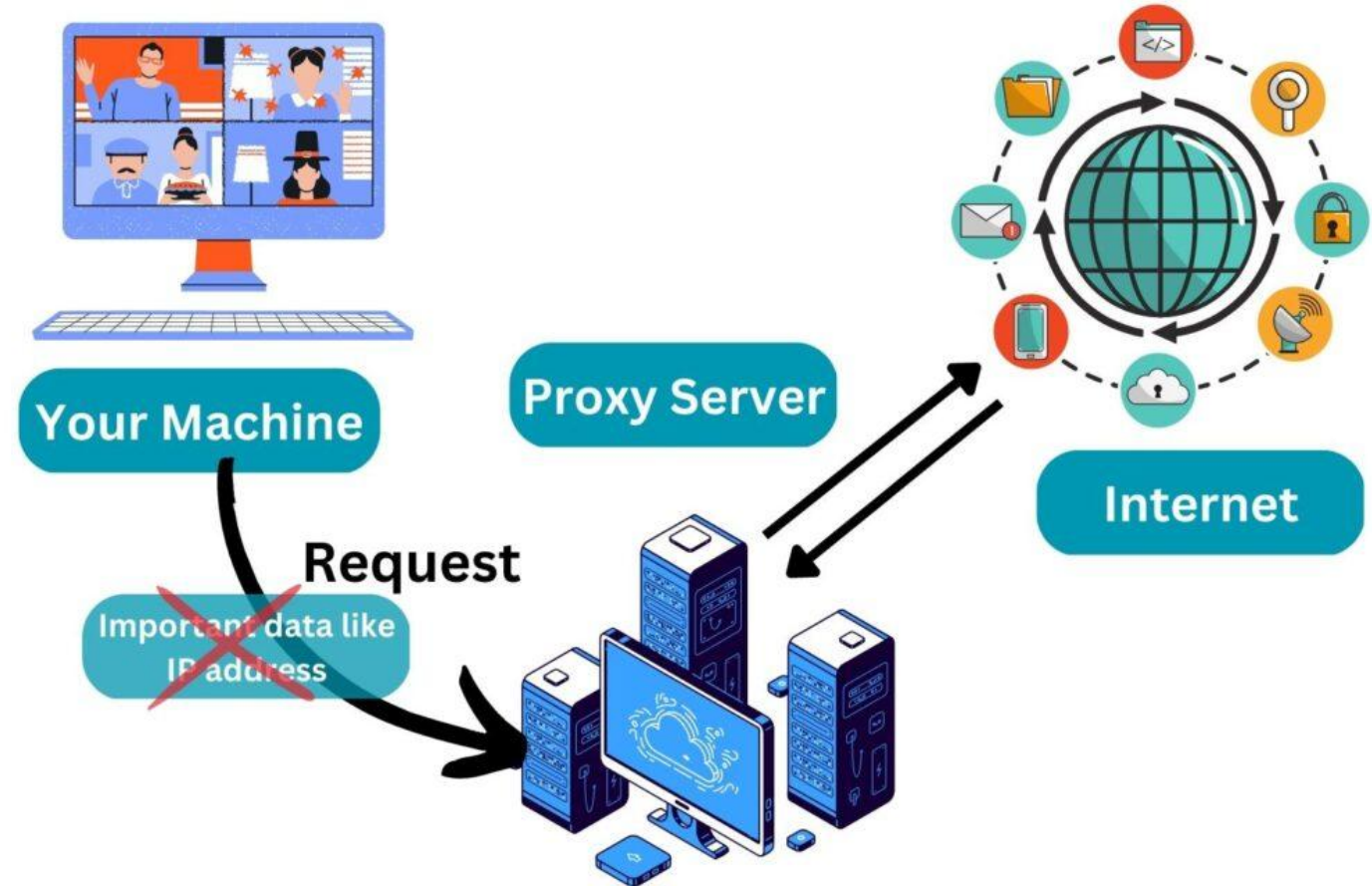
Tools Generating WAF Logs

- Cloudflare WAF
- AWS WAF
- Azure WAF
- F5 ASM / Advanced WAF
- Imperva WAF



Proxy

- Purpose of a Proxy in Security
 - Monitor and control web access
 - Enforce acceptable use policies
 - Detect malicious or risky web activity
 - Prevent data exfiltration
 - Provide detailed web activity logs
 - Support incident investigations

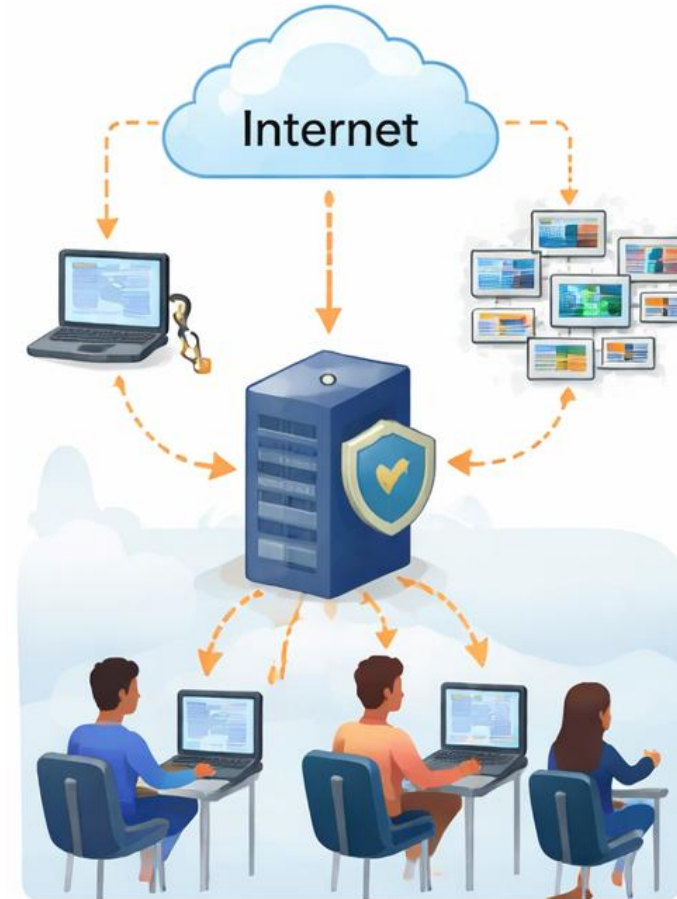


Types of Proxies

- **Forward Proxy**

- Placed between internal users and the internet.
- Use Cases
 - User web browsing control
 - Malware and phishing protection
 - URL filtering

Forward Proxy

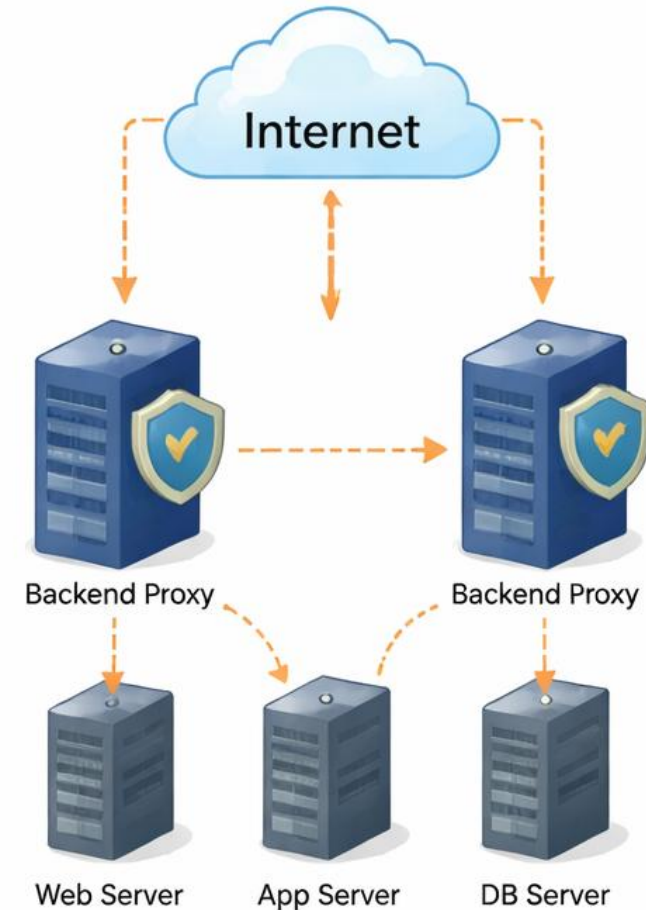


Types of Proxies

- **Reverse Proxy**

- Placed in front of web servers.
- Use Cases
 - Protect backend servers
 - Load balancing
 - SSL termination
 - Web application security

Reverse Proxy



Types of Proxies

- **Transparent Proxy**

- Intercepts traffic without client configuration.
- Use Cases
 - ISP-level or gateway enforcement
 - Monitoring without user awareness

Transparent Proxy



Common Proxy Solutions

- Zscaler Internet Access (ZIA)
- Blue Coat / Symantec Proxy
- Squid Proxy
- Cisco Umbrella (DNS-layer proxying)
- Forcepoint Web Security



Common Attack Indicators in Proxy Logs

- **Malware Download**

- Access to newly registered domains
- Executable file downloads

- **Command-and-Control (C2)**

- Repeated connections to rare domains
- Encrypted outbound traffic anomalies

- **Data Exfiltration**

- Large uploads to cloud storage
- Unusual POST requests

- **Policy Violations**

- Access to prohibited categories
- Circumventing security controls





That's all Folks!